

AXON TICKETS

Security Review Addendum - Product Packages

Controlled PDF edition

Converted from the master Markdown package for easier sharing and review. This PDF preserves the complete document contents, including sections, tables, and workflow blocks.

Source	reports/security-review-product-packages-2026-07-04.md
Generated	July 04, 2026

Security Review Addendum - Product Packages

Date: July 4, 2026

Reviewed scope: Referral codes, demographic collection, sponsor presentation, custom event sections, and migration 20260704180000_add_product_packages_mvp

Executive Result

No release-blocking vulnerability was found in the reviewed feature implementation. API and web production builds passed, the Prisma schema validated, and 202 API tests passed. UAT verification remains required before production promotion.

Controls Verified

Referral pricing and authorization

- Referral configuration and usage exports require authenticated event access.
- Codes are normalized and unique per event.
- Percentage discounts cannot exceed 100 percent; fixed discounts cannot reduce the subtotal below zero.
- The API retrieves the stored code and recalculates the discount. Client-supplied discount amounts are not trusted.
- A transaction-scoped PostgreSQL advisory lock serializes redemption by event and code before the maximum-usage check.
- Successful registrations store an immutable referral snapshot and one usage record.
- Referral preview validation is rate-limited.

Demographic information

- Birthday, gender, and city use strict DTO validation.
- Future and implausibly old birthdays are rejected.
- Public event responses do not expose attendee demographics.
- Operational access remains subject to registration ownership or event-management authorization.
- Privacy-safe reporting must remain aggregate-only with small-cohort suppression.

Sponsor and custom content

- Sponsor uploads accept JPG, PNG, and WebP only and apply file-size limits; SVG is rejected.
- Sponsor and custom-section links require HTTPS.
- React text rendering provides output escaping; no new raw HTML rendering sink was introduced.
- Organizer-controlled images load directly and lazily instead of being proxied through the Next.js image optimizer.
- Image alt text is required when a custom-section image is supplied.

Database migration

- The migration is additive: it creates referral tables and adds nullable/defaulted columns.
- Foreign keys and indexes support event isolation, one usage per registration, and reporting queries.

- Emergency application rollback must not drop populated columns or referral tables.

Performance Review

- Referral lists use database groupBy aggregation instead of loading all historical usage records.
- Referral lookup uses event/code uniqueness and event/active indexes.
- Usage reporting is indexed by referral code and creation time.
- The last-use concurrency lock prevents correctness failures at the cost of intentionally serializing redemptions for the same code only.
- Web production build completed with an 87.4 kB shared first-load bundle; the changed public event and registration routes remained within the existing application bundle profile.

Dependency Advisory Position

The repository continues to report pre-existing npm advisories whose automated remediation requires coordinated major upgrades of Next.js and NestJS. A partial framework-major upgrade produced an incompatible dependency graph and was not shipped. Compatible Multer and Nodemailer updates were retained, and the changed image flow was hardened directly. Framework upgrades must be handled as a separate migration with dedicated regression testing.

Required UAT Security Tests

- 1 Attempt cross-event referral administration and export with an unrelated organizer account.
- 2 Tamper with referral and discount request values.
- 3 Submit two simultaneous registrations against the final available referral use.
- 4 Test invalid, expired, future, wrong-tier, and inactive codes.
- 5 Upload SVG, oversized, and MIME-mismatched sponsor files.
- 6 Verify public responses contain no birthday, gender, city, or referral usage data.
- 7 Verify UAT records and uploads do not appear in production.

Release Decision

The feature code is suitable for UAT after the additive migration is applied. Production promotion requires completion of UAT-11 through UAT-14, documented privacy-owner approval of demographic retention, and no open P0 security or correctness defects.